

# QA Run Log

Printable sign-off sheet — one row per test case from `docs/QA_TEST_PLAN.md`. Mark each case **Pass** / **Fail** / **Blocked** / **N-A**. Run the Smoke suite first; if any Smoke case fails, stop and report.

|                      |                                                   |               |                            |
|----------------------|---------------------------------------------------|---------------|----------------------------|
| Tester               |                                                   | Date          | 2026-09-08                 |
| Build / commit SHA   |                                                   | Branch        |                            |
| Client(s) under test | Web [ ] Desktop [ ] Android [ ] iOS [ ] macOS [ ] | Mail delivery | Mailpit [ ] Real email [ ] |

183 cases — •20 Smoke •127 Core •36 Edge

## §4 Smoke suite (run first — ~15 min)

| Case ID   | Title                                               | Pri     | Client   | Result (circle one) | Notes / defect link |
|-----------|-----------------------------------------------------|---------|----------|---------------------|---------------------|
| QA-SMK-01 | Web: OTP sign-in happy path (Web) Automated in CI   | • Smoke |          | P / F / B / N-A     |                     |
| QA-SMK-02 | Web: Google OAuth sign-in                           | • Smoke | Web      | P / F / B / N-A     |                     |
| QA-SMK-03 | Web: Sign out (Web) Automated in CI                 | • Smoke |          | P / F / B / N-A     |                     |
| QA-SMK-04 | Web: Session persists across reload ("remember me") | • Smoke | Web      | P / F / B / N-A     |                     |
| QA-SMK-05 | Desktop: OTP sign-in                                | • Smoke | — alias  | P / F / B / N-A     |                     |
| QA-SMK-06 | Android: OTP sign-in                                | • Smoke | — alias  | P / F / B / N-A     |                     |
| QA-SMK-07 | API health & readiness                              | • Smoke | Platform | P / F / B / N-A     |                     |

## §5 Web — Authentication

| Case ID    | Title                                               | Pri    | Client | Result (circle one) | Notes / defect link |
|------------|-----------------------------------------------------|--------|--------|---------------------|---------------------|
| QA-AUTH-01 | Magic-link sign-in happy path (Web) Automated in CI | • Core |        | P / F / B / N-A     |                     |
| QA-AUTH-02 | Microsoft OAuth sign-in                             | • Core | Web    | P / F / B / N-A     |                     |
| QA-AUTH-03 | OTP wrong code is rejected                          | • Core | Web    | P / F / B / N-A     |                     |
| QA-AUTH-04 | OTP cumulative lockout & code expiry                | • Edge | Web    | P / F / B / N-A     |                     |
| QA-AUTH-11 | Passwordless endpoints are rate-limited             | • Core | Web    | P / F / B / N-A     |                     |
| QA-AUTH-05 | Magic link is single-use (Web) Automated in CI      | • Edge |        | P / F / B / N-A     |                     |
| QA-AUTH-06 | Magic link expiry                                   | • Edge | Web    | P / F / B / N-A     |                     |
| QA-AUTH-07 | User-enumeration protection                         | • Core | Web    | P / F / B / N-A     |                     |
| QA-AUTH-08 | Login error banners                                 | • Edge | Web    | P / F / B / N-A     |                     |
| QA-AUTH-09 | Email-format validation (Web) Automated in CI       | • Edge |        | P / F / B / N-A     |                     |
| QA-AUTH-10 | Magic link & OTP available on web; OAuth always     | • Edge | Web    | P / F / B / N-A     |                     |

## §6 Web — Onboarding & new tenant

| Case ID   | Title                                                      | Pri     | Client | Result (circle one) | Notes / defect link |
|-----------|------------------------------------------------------------|---------|--------|---------------------|---------------------|
| QA-ONB-01 | First-ever sign-in auto-creates a household, user is owner | • Smoke | Web    | P / F / B / N-A     |                     |
| QA-ONB-02 | Returning user keeps their household                       | • Core  | Web    | P / F / B / N-A     |                     |

## §7 Web — Household management

| Case ID  | Title                                                                                | Pri    | Client | Result (circle one) | Notes / defect link |
|----------|--------------------------------------------------------------------------------------|--------|--------|---------------------|---------------------|
| QA-HH-01 | Owner renames the household                                                          | • Core | Web    | P / F / B / N-A     |                     |
| QA-HH-02 | Member sees read-only household, no owner controls (Web) Automated in CI             | • Core |        | P / F / B / N-A     |                     |
| QA-HH-03 | Owner removes a member (Web) Automated in CI                                         | • Core |        | P / F / B / N-A     |                     |
| QA-HH-04 | Owner cannot remove themselves                                                       | • Edge | Web    | P / F / B / N-A     |                     |
| QA-HH-05 | Transfer ownership (Web) Automated in CI                                             | • Core |        | P / F / B / N-A     |                     |
| QA-HH-06 | Owner with other members cannot directly leave/dissolve                              | • Edge | Web    | P / F / B / N-A     |                     |
| QA-HH-07 | Sole owner dissolves the household (Web) Automated in CI                             | • Core |        | P / F / B / N-A     |                     |
| QA-HH-08 | Member leaves the household (Web) Automated in CI                                    | • Core |        | P / F / B / N-A     |                     |
| QA-HH-09 | Owner promotes a member to admin (Web) Automated in CI                               | • Core |        | P / F / B / N-A     |                     |
| QA-HH-10 | Owner demotes an admin to member (Web) Automated in CI                               | • Core |        | P / F / B / N-A     |                     |
| QA-HH-11 | Admin sees management controls but not role/ownership controls (Web) Automated in CI | • Core |        | P / F / B / N-A     |                     |
| QA-HH-12 | Member sees no management controls (Web) Automated in CI                             | • Edge |        | P / F / B / N-A     |                     |
| QA-HH-13 | Owner exports household data                                                         | • Core | Web    | P / F / B / N-A     |                     |
| QA-HH-14 | Seat quota blocks inviting past the plan limit (Web) Automated in CI                 | • Core |        | P / F / B / N-A     |                     |

## §8 Web — Invitations & joining

| Case ID   | Title                                                                                  | Pri     | Client | Result (circle one) | Notes / defect link |
|-----------|----------------------------------------------------------------------------------------|---------|--------|---------------------|---------------------|
| QA-INV-01 | Owner invites by email; token revealed + email sent (Web) Automated in CI              | • Smoke |        | P / F / B / N-A     |                     |
| QA-INV-02 | Invitee accepts and joins (two-user flow) (Web) Automated in CI                        | • Smoke |        | P / F / B / N-A     |                     |
| QA-INV-03 | Already-authenticated user accepts directly                                            | • Core  | Web    | P / F / B / N-A     |                     |
| QA-INV-04 | Join page with no token offers manual code entry                                       | • Edge  | Web    | P / F / B / N-A     |                     |
| QA-INV-05 | Join with invalid/expired/used token                                                   | • Core  | Web    | P / F / B / N-A     |                     |
| QA-INV-06 | Invite an existing member is rejected                                                  | • Core  | Web    | P / F / B / N-A     |                     |
| QA-INV-07 | Regenerate a pending invitation                                                        | • Core  | Web    | P / F / B / N-A     |                     |
| QA-INV-08 | Revoke a pending invitation (Web) Automated in CI                                      | • Core  |        | P / F / B / N-A     |                     |
| QA-INV-09 | Copy token button                                                                      | • Edge  | Web    | P / F / B / N-A     |                     |
| QA-INV-10 | Accepting an invite after a downgrade is refused (seat re-check) (Web) Automated in CI | • Core  |        | P / F / B / N-A     |                     |

## §9 Web — Settings / linked accounts

| Case ID   | Title                                                          | Pri    | Client | Result (circle one) | Notes / defect link |
|-----------|----------------------------------------------------------------|--------|--------|---------------------|---------------------|
| QA-SET-01 | View linked providers                                          | • Core | Web    | P / F / B / N-A     |                     |
| QA-SET-02 | Link a second provider                                         | • Core | Web    | P / F / B / N-A     |                     |
| QA-SET-03 | Linking a provider already used by another account is rejected | • Core | Web    | P / F / B / N-A     |                     |
| QA-SET-04 | Unlink a provider                                              | • Core | Web    | P / F / B / N-A     |                     |

| Case ID     | Title                                                                          | Pri    | Client          | Result (circle one) | Notes / defect link |
|-------------|--------------------------------------------------------------------------------|--------|-----------------|---------------------|---------------------|
| QA-SET-05   | Unlinking your only provider never locks you out                               | • Edge | Web             | P / F / B / N-A     |                     |
| QA-SET-06   | Settings requires auth                                                         | • Edge | Web             | P / F / B / N-A     |                     |
| QA-SET-07   | Delete my account (Web) Automated in CI                                        | • Core |                 | P / F / B / N-A     |                     |
| QA-SET-08   | Theme: dark mode applies, persists, and follows the user (Web) Automated in CI | • Core |                 | P / F / B / N-A     |                     |
| QA-MFA-01   | Enable two-factor (authenticator TOTP) (Web) Automated in CI                   | • Core |                 | P / F / B / N-A     |                     |
| QA-MFA-02   | Two-factor is required at sign-in (Web) Automated in CI                        | • Core |                 | P / F / B / N-A     |                     |
| QA-MFA-03   | Use a recovery code, then disable two-factor                                   | • Core | Web             | P / F / B / N-A     |                     |
| QA-MFA-04   | Redirect logins (OAuth / magic link) enforce the step-up                       | • Core | Web             | P / F / B / N-A     |                     |
| QA-MFA-05   | Native (MAUI) sign-in enforces the step-up                                     | • Core | Desktop/Android | P / F / B / N-A     |                     |
| QA-NOTIF-01 | Notification bell + list (Web) Automated in CI                                 | • Core |                 | P / F / B / N-A     |                     |
| QA-NOTIF-02 | Mark read / mark all read (Web) Automated in CI                                | • Core |                 | P / F / B / N-A     |                     |
| QA-NOTIF-04 | Delete a notification / clear read / clear all                                 | • Edge | Web             | P / F / B / N-A     |                     |
| QA-NOTIF-03 | Delivery preferences (Web) Automated in CI                                     | • Core |                 | P / F / B / N-A     |                     |

## §10 Web — Localization (i18n)

| Case ID    | Title                                                            | Pri    | Client | Result (circle one) | Notes / defect link |
|------------|------------------------------------------------------------------|--------|--------|---------------------|---------------------|
| QA-I18N-01 | Switch language on the login page (Web) Automated in CI          | • Core |        | P / F / B / N-A     |                     |
| QA-I18N-02 | Language persists per user across sessions (Web) Automated in CI | • Core |        | P / F / B / N-A     |                     |
| QA-I18N-03 | In-app UI is fully translated (no English leaks)                 | • Edge | Web    | P / F / B / N-A     |                     |
| QA-I18N-04 | Email language UI matches the requester's UI language            | • Core | Web    | P / F / B / N-A     |                     |

## §10b Web — Admin console (platform staff)

| Case ID     | Title                                                               | Pri    | Client | Result (circle one) | Notes / defect link |
|-------------|---------------------------------------------------------------------|--------|--------|---------------------|---------------------|
| QA-ADMIN-01 | Staff sees the console; non-staff don't (Web) Automated in CI       | • Core |        | P / F / B / N-A     |                     |
| QA-ADMIN-02 | View a tenant is audited in that tenant                             | • Core | Web    | P / F / B / N-A     |                     |
| QA-ADMIN-03 | Impersonate a user, then stop                                       | • Core | Web    | P / F / B / N-A     |                     |
| QA-ADMIN-04 | Staff announcement reaches a tenant's members (Web) Automated in CI | • Edge |        | P / F / B / N-A     |                     |
| QA-ADMIN-05 | Platform-wide broadcast reaches every user                          | • Edge | Web    | P / F / B / N-A     |                     |
| QA-ADMIN-06 | Comp a tenant to Pro and revert                                     | • Edge | Web    | P / F / B / N-A     |                     |
| QA-ADMIN-07 | Reset a locked-out user's MFA                                       | • Edge | Web    | P / F / B / N-A     |                     |

## §10c Web — Billing page

| Case ID    | Title                                                                      | Pri    | Client | Result (circle one) | Notes / defect link |
|------------|----------------------------------------------------------------------------|--------|--------|---------------------|---------------------|
| QA-BILL-01 | Billing page shows plan + seats; owner-only (Web) Automated in CI          | • Edge |        | P / F / B / N-A     |                     |
| QA-BILL-02 | Upgrade via checkout + provider webhook lands on Pro (Web) Automated in CI | • Core |        | P / F / B / N-A     |                     |

### §10d Web — Budget settings (app slice BUDGET-1)

| Case ID   | Title                                                    | Pri    | Client    | Result (circle one) | Notes / defect link |
|-----------|----------------------------------------------------------|--------|-----------|---------------------|---------------------|
| QA-BUD-01 | A new household sees the budget defaults                 | • Core | Web       | P / F / B / N-A     |                     |
| QA-BUD-02 | Save the household's budget structure and see it persist | • Core | Web       | P / F / B / N-A     |                     |
| QA-BUD-03 | Invalid values are refused and nothing changes           | • Core | Web / API | P / F / B / N-A     |                     |

### §10e Web — Catalog: categories & banks (app slice CATALOG-1/2)

| Case ID   | Title                                                                               | Pri    | Client    | Result (circle one) | Notes / defect link |
|-----------|-------------------------------------------------------------------------------------|--------|-----------|---------------------|---------------------|
| QA-CAT-01 | A new household's first visit seeds the defaults in its language                    | • Core | Web       | P / F / B / N-A     |                     |
| QA-CAT-02 | Create a category; a duplicate name is refused case-insensitively                   | • Core | Web       | P / F / B / N-A     |                     |
| QA-CAT-03 | Deactivate, then the inactive clash offers Reactivate                               | • Core | Web       | P / F / B / N-A     |                     |
| QA-CAT-04 | Banks behave the same and are household-wide                                        | • Core | Web / API | P / F / B / N-A     |                     |
| QA-CAT-05 | Cards: a voucher names the card, the household renames it, manual entry may pick it | • Core | Web / API | P / F / B / N-A     |                     |

### §10f Web — Exchange rate (app slice FX-1)

| Case ID  | Title                                                                                  | Pri    | Client    | Result (circle one) | Notes / defect link |
|----------|----------------------------------------------------------------------------------------|--------|-----------|---------------------|---------------------|
| QA-FX-01 | The dashboard shows today's BCCR buy/sell pair, and each currency freezes its own side | • Core | Web / API | P / F / B / N-A     |                     |
| QA-FX-02 | No provider -> the honest "unavailable" state, never a fabricated rate                 | • Core | Web / API | P / F / B / N-A     |                     |

### §10g Web — Envelopes (app slice ENV-1)

| Case ID   | Title                                                                  | Pri    | Client    | Result (circle one) | Notes / defect link |
|-----------|------------------------------------------------------------------------|--------|-----------|---------------------|---------------------|
| QA-ENV-01 | Create an envelope with targets and a reminder; duplicates are refused | • Core | Web / API | P / F / B / N-A     |                     |
| QA-ENV-02 | Edit, deactivate, then the inactive clash restores it                  | • Core | Web / API | P / F / B / N-A     |                     |

### §10h Web — Months & transactions (app slice LEDGER-1/2)

| Case ID   | Title                                                                     | Pri    | Client    | Result (circle one) | Notes / defect link |
|-----------|---------------------------------------------------------------------------|--------|-----------|---------------------|---------------------|
| QA-LED-01 | The first transaction creates its month with weeks and an income snapshot | • Core | Web / API | P / F / B / N-A     |                     |
| QA-LED-02 | Edit keeps the frozen rate; a date fix moves the transaction              | • Core | Web / API | P / F / B / N-A     |                     |
| QA-LED-03 | Deleting the last transaction removes the month                           | • Core | Web / API | P / F / B / N-A     |                     |
| QA-LED-04 | Month income is editable; invalid input and foreign ids are refused       | • Core | Web / API | P / F / B / N-A     |                     |

| Case ID   | Title                                                                          | Pri    | Client    | Result (circle one) | Notes / defect link |
|-----------|--------------------------------------------------------------------------------|--------|-----------|---------------------|---------------------|
| QA-LED-05 | An unplanned essential can expect a refund; the refund follows the transaction | • Core | Web / API | P / F / B / N-A     |                     |
| QA-LED-06 | Marking a refund received books an inflow; reverting removes it                | • Core | Web / API | P / F / B / N-A     |                     |
| QA-LED-07 | A transaction can carry a short note; the month page shows it as an icon       | • Edge | Web / API | P / F / B / N-A     |                     |

### §10i Web — Budget lines: fixed & variable (app slice EXPENSES-1)

| Case ID   | Title                                                                               | Pri    | Client    | Result (circle one) | Notes / defect link |
|-----------|-------------------------------------------------------------------------------------|--------|-----------|---------------------|---------------------|
| QA-EXP-01 | Create fixed and variable lines; the single-currency and category rules hold        | • Core | Web / API | P / F / B / N-A     |                     |
| QA-EXP-02 | Reorder with ▲▼; inactive lines stay out of the order                               | • Core | Web / API | P / F / B / N-A     |                     |
| QA-EXP-03 | Duplicate names per list; the inactive clash restores the line; foreign ids are 404 | • Core | Web / API | P / F / B / N-A     |                     |

### §10j Web — Dashboard (app slice DASH-1)

| Case ID    | Title                                                                                        | Pri    | Client    | Result (circle one) | Notes / defect link |
|------------|----------------------------------------------------------------------------------------------|--------|-----------|---------------------|---------------------|
| QA-DASH-01 | The dashboard reflects income, lines vs actuals, other spending and the balance              | • Core | Web / API | P / F / B / N-A     |                     |
| QA-DASH-02 | Month selector, entry points, empty state, and the blocked projections when no rate resolves | • Core | Web / API | P / F / B / N-A     |                     |

### §10k Web — Reports: category analysis & CSV export (app slice REPORTS-1/2)

| Case ID    | Title                                                                                    | Pri    | Client    | Result (circle one) | Notes / defect link |
|------------|------------------------------------------------------------------------------------------|--------|-----------|---------------------|---------------------|
| QA-DASH-03 | "Show in" follows the account, and a first choice on a device follows you                | • Core | Web / API | P / F / B / N-A     |                     |
| QA-REP-01  | Category analysis by month shows budgets; a date range doesn't                           | • Core | Web / API | P / F / B / N-A     |                     |
| QA-REP-02  | Export CSV downloads the shown period; the file has the fixed columns and 4-decimal rate | • Core | Web / API | P / F / B / N-A     |                     |

### §10l Web — Email inboxes: connect, filters & readers (app slice EMAIL-2/3)

| Case ID     | Title                                                                             | Pri    | Client    | Result (circle one) | Notes / defect link |
|-------------|-----------------------------------------------------------------------------------|--------|-----------|---------------------|---------------------|
| QA-EMAIL-01 | The Email settings page without credentials: honest errors, no dead ends          | • Core | Web / API | P / F / B / N-A     |                     |
| QA-EMAIL-02 | Live consent round-trip (IdP boundary) and the pre-seeded connection              | • Core | Web       | P / F / B / N-A     |                     |
| QA-EMAIL-03 | Edit with real folders, backfill rule, disconnect, and nothing leaks across users | • Core | Web / API | P / F / B / N-A     |                     |

### §10m Web — Email ingestion: staging & dedup (app slice EMAIL-4)

| Case ID     | Title                                                                    | Pri    | Client    | Result (circle one) | Notes / defect link |
|-------------|--------------------------------------------------------------------------|--------|-----------|---------------------|---------------------|
| QA-EMAIL-04 | Sync now stages drafts once, dedups re-fetches, and a dead inbox says so | • Core | Web / API | P / F / B / N-A     |                     |

### §10n Web — Email ingestion: suggestions & review queue (app slice EMAIL-5/6)

| Case ID     | Title                                                                             | Pri    | Client    | Result (circle one) | Notes / defect link |
|-------------|-----------------------------------------------------------------------------------|--------|-----------|---------------------|---------------------|
| QA-EMAIL-05 | Merchant rules suggest, never apply, and are unique per household                 | • Core | Web / API | P / F / B / N-A     |                     |
| QA-EMAIL-06 | Review queue: confirm books the transaction once, discard never reverts a confirm | • Core | Web / API | P / F / B / N-A     |                     |

## §11 Emails (Mailpit) — branding & content

| Case ID    | Title                          | Pri    | Client | Result (circle one) | Notes / defect link |
|------------|--------------------------------|--------|--------|---------------------|---------------------|
| QA-MAIL-01 | OTP email is branded & correct | • Core |        | P / F / B / N-A     |                     |
| QA-MAIL-02 | Magic-link email               | • Core |        | P / F / B / N-A     |                     |
| QA-MAIL-03 | Invitation email               | • Core |        | P / F / B / N-A     |                     |
| QA-MAIL-04 | Logo renders in a real client  | • Edge |        | P / F / B / N-A     |                     |

## §12 Desktop — MAUI / Windows

| Case ID   | Title                                                 | Pri     | Client  | Result (circle one) | Notes / defect link |
|-----------|-------------------------------------------------------|---------|---------|---------------------|---------------------|
| QA-DSK-01 | OTP sign-in (Desktop) — CI covers boot-to-login only  | • Smoke |         | P / F / B / N-A     |                     |
| QA-DSK-02 | Google OAuth via loopback                             | • Core  | Desktop | P / F / B / N-A     |                     |
| QA-DSK-03 | "Remember me" across app restart                      | • Core  | Desktop | P / F / B / N-A     |                     |
| QA-DSK-04 | Household & Settings load (authorized API calls)      | • Core  | Desktop | P / F / B / N-A     |                     |
| QA-DSK-05 | Link a provider from Settings                         | • Edge  | Desktop | P / F / B / N-A     |                     |
| QA-DSK-06 | Sign out                                              | • Edge  | Desktop | P / F / B / N-A     |                     |
| QA-DSK-07 | Core household flows work on desktop                  | • Edge  | Desktop | P / F / B / N-A     |                     |
| QA-DSK-08 | Join a household by pasted invite code                | • Core  | Desktop | P / F / B / N-A     |                     |
| QA-DSK-09 | Language choice survives an app restart               | • Core  | Desktop | P / F / B / N-A     |                     |
| QA-DSK-10 | Data export downloads via the OS                      | • Core  | Desktop | P / F / B / N-A     |                     |
| QA-DSK-11 | Billing: checkout leaves, summary refreshes on return | • Core  | Desktop | P / F / B / N-A     |                     |
| QA-DSK-12 | MFA: enroll and native step-up                        | • Core  | Desktop | P / F / B / N-A     |                     |
| QA-DSK-13 | Notification bell & preferences                       | • Edge  | Desktop | P / F / B / N-A     |                     |
| QA-DSK-14 | Admin console on desktop (staff only)                 | • Edge  | Desktop | P / F / B / N-A     |                     |
| QA-DSK-15 | Theme: dark mode survives an app restart              | • Edge  | Desktop | P / F / B / N-A     |                     |

## §13 Android — MAUI

| Case ID   | Title                                   | Pri     | Client  | Result (circle one) | Notes / defect link |
|-----------|-----------------------------------------|---------|---------|---------------------|---------------------|
| QA-AND-01 | OTP sign-in (Android) Automated in CI   | • Smoke |         | P / F / B / N-A     |                     |
| QA-AND-02 | Google OAuth via custom scheme          | • Core  | Android | P / F / B / N-A     |                     |
| QA-AND-03 | "Remember me" across app restart        | • Core  | Android | P / F / B / N-A     |                     |
| QA-AND-04 | Household & Settings load               | • Core  | Android | P / F / B / N-A     |                     |
| QA-AND-05 | Navigation drawer / header is reachable | • Edge  | Android | P / F / B / N-A     |                     |
| QA-AND-06 | Core flows on Android                   | • Edge  | Android | P / F / B / N-A     |                     |
| QA-AND-07 | Hardware back navigates in-app history  | • Smoke | Android | P / F / B / N-A     |                     |
| QA-AND-08 | Join a household by pasted invite code  | • Core  | Android | P / F / B / N-A     |                     |
| QA-AND-09 | Language choice survives an app restart | • Core  | Android | P / F / B / N-A     |                     |

| Case ID   | Title                                                 | Pri    | Client  | Result (circle one) | Notes / defect link |
|-----------|-------------------------------------------------------|--------|---------|---------------------|---------------------|
| QA-AND-10 | Data export via the share sheet                       | • Core | Android | P / F / B / N-A     |                     |
| QA-AND-11 | Billing: checkout leaves, summary refreshes on return | • Core | Android | P / F / B / N-A     |                     |
| QA-AND-12 | MFA: enroll and native step-up                        | • Core | Android | P / F / B / N-A     |                     |
| QA-AND-13 | Edge-to-edge / status bar on Android 15               | • Edge | Android | P / F / B / N-A     |                     |
| QA-AND-14 | Theme: dark mode survives an app restart              | • Edge | Android | P / F / B / N-A     |                     |
| QA-AND-15 | OAuth sign-in survives process death (NATIVE-12)      | • Core | Android | P / F / B / N-A     |                     |

### §13b iOS + macCatalyst — first-run smoke

| Case ID   | Title                                | Pri     | Client      | Result (circle one) | Notes / defect link |
|-----------|--------------------------------------|---------|-------------|---------------------|---------------------|
| QA-IOS-01 | App boots to the login screen        | • Smoke | iOS         | P / F / B / N-A     |                     |
| QA-IOS-02 | OTP sign-in                          | • Smoke | iOS         | P / F / B / N-A     |                     |
| QA-IOS-03 | Core flows spot-check                | • Core  | iOS         | P / F / B / N-A     |                     |
| QA-IOS-04 | OAuth via ASWebAuthenticationSession | • Core  | iOS         | P / F / B / N-A     |                     |
| QA-MAC-01 | App launches at a usable window      | • Smoke | macCatalyst | P / F / B / N-A     |                     |
| QA-MAC-02 | OTP sign-in                          | • Smoke | macCatalyst | P / F / B / N-A     |                     |
| QA-MAC-03 | Core flows + OAuth spot-check        | • Core  | macCatalyst | P / F / B / N-A     |                     |

### §14 Cross-cutting security

| Case ID   | Title                          | Pri     | Client          | Result (circle one) | Notes / defect link |
|-----------|--------------------------------|---------|-----------------|---------------------|---------------------|
| QA-SEC-01 | Tenant isolation               | • Smoke |                 | P / F / B / N-A     |                     |
| QA-SEC-02 | Protected pages require auth   | • Core  |                 | P / F / B / N-A     |                     |
| QA-SEC-03 | Session is gone after sign-out | • Core  |                 | P / F / B / N-A     |                     |
| QA-SEC-04 | Native open-redirect guard     | • Edge  | Desktop/Android | P / F / B / N-A     |                     |
| QA-SEC-05 | Server-side hardening          | • Edge  |                 | P / F / B / N-A     |                     |

### §14a Adversarial & tenant-isolation (QA-ADV-\*)

| Case ID   | Title                                                                                        | Pri     | Client                    | Result (circle one) | Notes / defect link |
|-----------|----------------------------------------------------------------------------------------------|---------|---------------------------|---------------------|---------------------|
| QA-ADV-01 | Tenant A cannot read/export/erase Tenant B via the API                                       | • Smoke | curl                      | P / F / B / N-A     |                     |
| QA-ADV-02 | Cross-tenant isolation on the newer tables (PUBAPI/HOOKS on)                                 | • Core  | curl                      | P / F / B / N-A     |                     |
| QA-ADV-03 | Export includes EVERY tenant-scoped table, secret-free                                       | • Core  | curl                      | P / F / B / N-A     |                     |
| QA-ADV-04 | Dissolve / erasure actually deletes api keys, webhook secrets, usage counters, delivery logs | • Core  | curl + DB                 | P / F / B / N-A     |                     |
| QA-ADV-05 | Writes during impersonation are attributed to the acting staff                               | • Core  | curl                      | P / F / B / N-A     |                     |
| QA-ADV-06 | An impersonation session cannot reach staff-only actions                                     | • Core  | curl                      | P / F / B / N-A     |                     |
| QA-ADV-07 | Impersonation cannot exceed the target's role                                                | • Core  | curl                      | P / F / B / N-A     |                     |
| QA-ADV-08 | Impersonation never rewrites target prefs; shared-device pref poisoning                      | • Core  | curl + Web — two contexts | P / F / B / N-A     |                     |

| Case ID   | Title                                                                                       | Pri     | Client             | Result (circle one) | Notes / defect link |
|-----------|---------------------------------------------------------------------------------------------|---------|--------------------|---------------------|---------------------|
| QA-ADV-09 | A staff MFA-reset notification cannot be silenced by target prefs                           | • Core  | curl               | P / F / B / N-A     |                     |
| QA-ADV-10 | MFA step-up locks out after repeated wrong codes                                            | • Core  | curl               | P / F / B / N-A     |                     |
| QA-ADV-11 | A recovery code is single-use                                                               | • Core  | Web                | P / F / B / N-A     |                     |
| QA-ADV-12 | Webhook replay + out-of-order + same-second idempotency                                     | • Core  | curl               | P / F / B / N-A     |                     |
| QA-ADV-13 | A first-ever webhook in a bad state does not false-notify                                   | • Core  | curl               | P / F / B / N-A     |                     |
| QA-ADV-14 | Comp / revert a churned (canceled) tenant                                                   | • Core  | curl               | P / F / B / N-A     |                     |
| QA-ADV-15 | Concurrent acceptance of the last seat                                                      | • Core  | Web — two contexts | P / F / B / N-A     |                     |
| QA-ADV-16 | Magic-link / OTP double-redemption issues exactly one session                               | • Core  | Web — two contexts | P / F / B / N-A     |                     |
| QA-ADV-17 | Replaying a rotated refresh token revokes all sessions                                      | • Core  | curl               | P / F / B / N-A     |                     |
| QA-ADV-18 | Spanish account on an English device accepts an invite (Web — two contexts) Automated in CI | • Smoke |                    | P / F / B / N-A     |                     |
| QA-ADV-19 | Theme/locale doesn't revert after a soft (OTP/MFA) sign-in                                  | • Core  | Web                | P / F / B / N-A     |                     |
| QA-ADV-20 | "Clear read" never deletes unread notifications                                             | • Core  | Web                | P / F / B / N-A     |                     |
| QA-ADV-21 | Security headers on the single-origin host (staging / Environment B)                        | • Core  | curl               | P / F / B / N-A     |                     |
| QA-ADV-22 | Forged X-Forwarded-For cannot bypass the per-IP rate limit                                  | • Core  | curl               | P / F / B / N-A     |                     |
| QA-ADV-23 | A Release native build points at a real HTTPS base URL, not cleartext localhost             | • Core  | Desktop/Android    | P / F / B / N-A     |                     |
| QA-ADV-24 | Windows loopback OAuth binds state (login-CSRF guard)                                       | • Edge  | Desktop            | P / F / B / N-A     |                     |

## §14b API surfaces — PUBAPI + HOOKS (config-gated; curl / Postman)

| Case ID   | Title                                                     | Pri    | Client         | Result (circle one) | Notes / defect link |
|-----------|-----------------------------------------------------------|--------|----------------|---------------------|---------------------|
| QA-API-01 | Config gate: surfaces are 404 when disabled               | • Edge | curl           | P / F / B / N-A     |                     |
| QA-API-02 | Mint an API key (shown once)                              | • Core | curl           | P / F / B / N-A     |                     |
| QA-API-03 | Call the public API with the key; scopes + tenant-scoping | • Core | curl / Postman | P / F / B / N-A     |                     |
| QA-API-04 | Per-key rate limit                                        | • Core | curl           | P / F / B / N-A     |                     |
| QA-API-05 | Register a webhook + send test + verify signature         | • Core | curl           | P / F / B / N-A     |                     |
| QA-API-06 | Delivery log + replay                                     | • Core | curl           | P / F / B / N-A     |                     |

## Release gate

All • **Smoke** + all • **Core** cases Pass on Web; • Smoke Pass on Desktop and Android; no open Critical/High defects. • Edge cases triaged (Pass or accepted-known-issue).

|                 |                                   |        |  |
|-----------------|-----------------------------------|--------|--|
| Overall verdict | PASS [ ] FAIL [ ] CONDITIONAL [ ] | Signed |  |
|-----------------|-----------------------------------|--------|--|